

CISM CERTIFICATION EXAM SIMULATOR

Practice Exam 13

Domain I - Information Security Governance

27 Questions	43 Minutes	Single Best Answer Format
-----------------	---------------	------------------------------

This publication contains original practice material designed for exam preparation. It does not reproduce confidential certification questions and is not affiliated with or endorsed by ISACA.

Instructions

- Allow approximately 43 minutes for this domain set.
- Select one best answer for every question.
- Record your selections before consulting the answer key.
- Review every explanation, including questions you answered correctly.

Questions

Question 1 (CISM4-001)

Which outcome BEST demonstrates effective information security governance?

- A. All security decisions are made by technical specialists.
- B. Security spending increases every year regardless of business change.
- C. Business units avoid documenting accepted information risk.
- D. Authorized leaders make informed security decisions aligned with enterprise objectives and risk appetite.

Question 2 (CISM4-002)

Scenario: In a family-owned manufacturing group, employees rarely challenge senior managers. Security concerns affecting executive-sponsored projects are therefore reported late or not at all.

What should the information security manager recommend FIRST?

- A. Require employees to confront project sponsors directly in public meetings.
- B. Limit risk reporting to annual internal audit interviews.
- C. Create trusted escalation channels, protect good-faith reporting, and have leaders model openness to challenge.
- D. Assume silence means that executive-sponsored projects have acceptable risk.

Question 3 (CISM4-003)

Scenario: A digital lending company becomes subject to a new supervisory requirement for timely reporting of material service disruptions. Security, legal, operations, and communications teams each assume another function owns compliance.

What is the BEST governance response?

- A. Interpret the requirement, define reporting criteria and workflows, and assign an accountable business owner.
- B. Assign the entire obligation to the security operations center because it detects incidents.
- C. Wait for the first disruption to determine which team should report it.
- D. Allow each function to create an independent materiality definition.

Question 4 (CISM4-004)

Which document should define a security steering committee's mandate, membership, decision authority, and escalation responsibilities?

- A. A vulnerability assessment report
- B. A committee charter
- C. A technical configuration baseline
- D. An individual project schedule

Question 5 (CISM4-005)

Scenario: An enterprise risk committee, technology committee, and security steering committee all review the same major security investments. Their charters do not specify which forum makes the final decision, causing repeated reviews and conflicting directions.

What should senior leadership do?

- A. Require unanimous approval from every committee for all investments.
- B. Let project teams choose which decision to follow.
- C. Clarify decision rights, information flows, and escalation paths across the governance forums.
- D. Transfer final investment authority to external auditors.

Question 6 (CISM4-006)

Scenario: A hospital network is creating a remote-care capability that changes clinical processes, patient information flows, applications, and external service dependencies. Technology selection has not yet begun.

How should the information security manager contribute?

- A. Define security and risk requirements with business and architecture stakeholders during capability design.
- B. Wait for the final technology design before identifying information risk.
- C. Select all remote-care technologies independently of clinical leadership.
- D. Require the new capability to reproduce every legacy process and control.

Question 7 (CISM4-007)

What is the PRIMARY benefit of documenting security roles and responsibilities?

- A. It ensures that one person performs every stage of each critical process.
- B. It transfers all control accountability to the information security manager.
- C. It eliminates the need for coordination among participating functions.
- D. It clarifies ownership, expected actions, and escalation while reducing gaps and duplication.

Question 8 (CISM4-008)

Scenario: A media platform is negotiating a partnership that requires it to guarantee uninterrupted service and accept unlimited liability for any security event. Its current architecture cannot meet the proposed availability commitment.

What should the information security manager recommend?

- A. Sign immediately because the partnership has high revenue potential.
- B. Present capability gaps and exposure for leaders to negotiate obligations and risk allocation.
- C. Accept the security terms and plan improvements after the contract begins.
- D. Reject every partnership containing security-related contractual obligations.

Question 9 (CISM4-009)

Scenario: A procurement manager selects security service providers, approves their invoices, accepts all service exceptions, and certifies that the providers meet contractual requirements.

Which change would MOST improve governance?

- A. Allow providers to certify their own compliance.
- B. Separate assurance and exception approval from the procurement manager's conflicting duties.
- C. Approve exceptions automatically when invoices are current.
- D. Remove all procurement involvement from supplier management.

Question 10 (CISM4-010)

Scenario: A remote production site requests a permanent exception from the enterprise connectivity architecture because the approved service is unreliable in that location. The proposed alternative introduces new support and security dependencies.

What should the information security manager do FIRST?

- A. Approve the exception because local availability is the only relevant factor.
- B. Allow the local vendor to accept the enterprise's residual risk.
- C. Reject the request because architecture principles may never have exceptions.
- D. Assess business need, security exposure, support implications, alternatives, and alignment with the target architecture.

Question 11 (CISM4-011)

Which statement is the BEST example of an information security strategic objective?

- A. Reduce disruption to critical services within risk tolerance over two years.
- B. Install as many security tools as the annual budget permits.
- C. Review an individual system log every Monday morning.
- D. Replace every existing technical procedure regardless of business need.

Question 12 (CISM4-012)

Scenario: A food delivery company adopts a franchise model while threat intelligence indicates increased attacks against distributed partner accounts.

Why should both developments influence the security strategy?

- A. Only external threats are relevant to strategic planning.
- B. Only internal business changes affect desired security capabilities.
- C. Neither development matters until a confirmed loss occurs.
- D. The operating model and threats change dependencies, exposure, and capability needs.

Question 13 (CISM4-013)

Scenario: An insurer's desired state requires business owners to make consistent risk decisions using defined criteria. The current state has no documented risk ownership and each department uses different rating methods.

What should the information security manager do NEXT?

- A. Purchase a risk platform before defining governance requirements.
- B. Measure success by the number of risk records created.
- C. Define governance capabilities and prioritize initiatives closing ownership and criteria gaps.
- D. Allow each department to preserve its current method indefinitely.

Question 14 (CISM4-014)

Scenario: A growing technology cooperative is comparing several established security governance frameworks. The evaluation team ranks them only by the number of controls they contain.

Which selection criterion is MOST important?

- A. The amount of terminology unique to the framework
- B. Whether the framework can be implemented without tailoring
- C. The number of commercial tools advertised as compatible
- D. Its fit with objectives, risks, obligations, operations, and existing practices.

Question 15 (CISM4-015)

Scenario: A university can fund only one initiative: modernizing identity governance needed for a new research partnership, replacing a functional dashboard for visual consistency, or automating reports that few leaders use.

Which initiative should receive the HIGHEST priority?

- A. Identity governance because it enables an approved enterprise objective and addresses associated access risk.
- B. The dashboard because its benefits are immediately visible.
- C. Report automation because it produces the largest number of documents.
- D. Divide the funds equally even if no initiative can then be completed.

Question 16 (CISM4-016)

Scenario: Executives approved a data governance strategy but have not resolved disputes over ownership between product, legal, and operations leaders. Project teams continue building technology without authoritative data owners.

What is the PRIMARY strategic concern?

- A. The project team needs more frequent technical meetings.
- B. The strategy contains too few software purchases.
- C. Leadership sponsorship has not produced the ownership decisions required for execution.
- D. Data ownership should be assigned entirely to external developers.

Question 17 (CISM4-017)

Scenario: A public benefits agency plans to replace in-person verification with reusable digital credentials. The security roadmap still funds improvements designed only for physical identity checks.

What should the information security manager do FIRST?

- A. Continue the existing roadmap until every physical office closes.
- B. Reassess risks and capabilities against the new business process and target architecture.
- C. Transfer security strategy ownership to the architecture team.
- D. Purchase credential technology before defining target requirements.

Question 18 (CISM4-018)

Scenario: A wholesale distributor wants to reduce unauthorized use of dormant accounts. Its dashboard reports the number of account review reminders sent.

Which metric BEST indicates achievement of the strategic objective?

- A. The number of reminder templates available
- B. The number of administrators receiving reminders
- C. The percentage of dormant accounts disabled within the approved time limit
- D. The total length of the account management procedure

Question 19 (CISM4-019)

Scenario: A regional bank acquires a digital wallet company. Both organizations have overlapping security technologies, different risk processes, and incompatible customer information models. Investment proposals assume both environments will remain separate.

What should the information security manager recommend FIRST?

- A. Compare current capabilities with the integration strategy and target architecture before approving investments.
- B. Renew every overlapping technology contract to preserve optionality.
- C. Select whichever risk process has more documented steps.
- D. Delay all security governance until technical integration is complete.

Question 20 (CISM4-020)

Scenario: A transportation operator needs a new supplier assurance capability within nine months. Existing employees understand operations but lack specialized assessment skills, and permanent recruitment will not finish in time.

What is the MOST appropriate response?

- A. Abandon the capability because current employees lack every required skill.
- B. Use targeted training and temporary specialist support while retaining enterprise ownership and oversight.
- C. Outsource accountability for supplier risk to a consulting firm.
- D. Purchase an assessment tool and assume no additional expertise is needed.

Question 21 (CISM4-021)

Which information is MOST important in a security investment business case?

- A. Expected outcomes, risk reduction, costs, alternatives, assumptions, and dependencies
- B. Only the amount remaining in the current budget
- C. Only the number of employees supporting the request
- D. Only the preferred product's technical features

Question 22 (CISM4-022)

Scenario: A global publisher is considering a managed security service to improve round-the-clock monitoring. The lowest-cost proposal meets basic coverage needs but provides limited access to evidence, weak performance measures, and no practical exit assistance.

What should the information security manager recommend?

- A. Reject all managed services because operational activities cannot be outsourced.
- B. Select the lowest-cost proposal because monitoring is a technical commodity.
- C. Allow the provider to define the publisher's risk appetite.
- D. Evaluate total value, assurance access, measurable outcomes, oversight, resilience, and exit needs before selection.

Question 23 (CISM4-023)

Scenario: A security steering committee receives a report listing completed tasks but cannot determine whether the strategy is reducing risk or enabling planned business changes.

How should the report be improved?

- A. Connect initiative progress, risk and outcome trends, resources, and decisions to objectives.
- B. Remove targets so unfavorable trends are less visible.
- C. Add every technical event generated by security tools.
- D. Report only projects that are on schedule.

Question 24 (CISM4-024)

Scenario: A logistics enterprise defines a maximum acceptable duration for unresolved critical supplier findings. The threshold has been exceeded for three consecutive quarters, but the roadmap gives supplier remediation no additional priority.

What should the information security manager do?

- A. Raise the tolerance automatically to match current performance.
- B. Stop measuring supplier findings until the backlog declines.
- C. Escalate the breach, impacts, and treatment options to authorized decision-makers.
- D. Accept the risk personally to preserve the roadmap.

Question 25 (CISM4-025)

Scenario: A company approves a strategy emphasizing shared accountability for information protection, but its policy still assigns every security responsibility exclusively to the security department.

What is the PRIMARY concern?

- A. Policies should never assign security responsibilities.
- B. The policy conflicts with the strategy and may reinforce incorrect ownership.
- C. The strategy should be changed to match every legacy policy statement.
- D. Only technical standards need to align with strategy.

Question 26 (CISM4-026)

Scenario: During the annual review, an agricultural cooperative finds that enterprise objectives are unchanged, but two initiatives are underperforming and a new supplier concentration risk has emerged.

What should the information security manager do?

- A. Renew the strategy unchanged because enterprise objectives remain stable.
- B. Revise affected priorities, initiatives, measures, and resource assumptions based on the new evidence.
- C. Replace every initiative regardless of performance.
- D. Remove supplier risk from consideration because it was not in the original strategy.

Question 27 (CISM4-027)

Scenario: A healthcare analytics firm plans rapid international expansion, enterprise architects propose a shared global data platform, and compliance leaders identify jurisdiction-specific processing restrictions. Separate teams have submitted conflicting security investments.

What should the information security manager recommend FIRST?

- A. Approve every investment to avoid delaying expansion.
- B. Let each jurisdiction create an unrelated security strategy.
- C. Reconcile business goals, obligations, architecture, risk appetite, and capability priorities.
- D. Adopt the architecture proposal without evaluating regulatory constraints.

Answer Key

Domain I - Information Security Governance

1 D	2 C	3 A	4 B	5 C
6 A	7 D	8 B	9 B	10 D
11 A	12 D	13 C	14 D	15 A
16 C	17 B	18 C	19 A	20 B
21 A	22 D	23 A	24 C	25 B
26 B	27 C			

Detailed Explanations

Question 1 (CISM4-001)

Correct answer: D - Authorized leaders make informed security decisions aligned with enterprise objectives and risk appetite.

Effective governance provides decision-makers with reliable information, clear authority, and alignment to enterprise objectives and risk appetite. Technical specialists advise but do not own every business decision, spending growth is not inherently effective, and undocumented risk acceptance weakens accountability.

Question 2 (CISM4-002)

Correct answer: C - Create trusted escalation channels, protect good-faith reporting, and have leaders model openness to challenge.

Trusted escalation channels and visible leadership support address the cultural barrier while preserving accountable review. Forced public confrontation may discourage reporting, annual interviews are too infrequent, and silence is not evidence that risk is acceptable.

Question 3 (CISM4-003)

Correct answer: A - Interpret the requirement, define reporting criteria and workflows, and assign an accountable business owner.

A consistent interpretation, defined workflow, decision criteria, and accountable owner are necessary for reliable regulatory reporting. Detection does not confer end-to-end ownership, waiting creates compliance risk, and independent materiality definitions can produce inconsistent decisions.

Question 4 (CISM4-004)

Correct answer: B - A committee charter

A committee charter formally defines the forum's mandate, membership, authority, and escalation responsibilities. Assessment reports describe findings, configuration baselines prescribe technical settings, and project schedules organize delivery activities rather than governance authority.

Question 5 (CISM4-005)

Correct answer: C - Clarify decision rights, information flows, and escalation paths across the governance forums.

Clear decision rights and escalation paths eliminate duplication while preserving appropriate input from each forum. Universal unanimous approval may worsen delays, project teams should not choose among conflicting authorities, and external auditors must remain independent of management investment decisions.

Question 6 (CISM4-006)

Correct answer: A - Define security and risk requirements with business and architecture stakeholders during capability design.

Early collaboration allows security requirements to influence processes, information, applications, and service dependencies before choices become costly to change. Waiting is too late, security should not select the entire solution independently, and replicating legacy designs may conflict with the intended business capability.

Question 7 (CISM4-007)

Correct answer: D - It clarifies ownership, expected actions, and escalation while reducing gaps and duplication.

Documented roles clarify ownership, responsibilities, and escalation, reducing omitted or duplicated work. They do not centralize all accountability in security, eliminate collaboration, or place incompatible process stages with one person.

Question 8 (CISM4-008)

Correct answer: B - Present capability gaps and exposure for leaders to negotiate obligations and risk allocation.

Authorized leaders need the capability gaps, potential exposure, costs, and alternatives to negotiate commitments the enterprise can govern and fulfill. Revenue does not eliminate risk, post-signature remediation may be too late, and categorical rejection ignores legitimate business opportunities.

Question 9 (CISM4-009)

Correct answer: B - Separate assurance and exception approval from the procurement manager's conflicting duties.

Independent assurance and separate exception authority reduce conflicts created by combining selection, payment, acceptance, and assessment. Provider self-certification alone is insufficient, procurement still has legitimate responsibilities, and invoice status does not justify risk exceptions.

Question 10 (CISM4-010)

Correct answer: D - Assess business need, security exposure, support implications, alternatives, and alignment with the target architecture.

A complete impact assessment enables the authorized architecture forum to balance local need, security, supportability, alternatives, and enterprise direction. Availability alone is incomplete, exceptions may be justified through governance, and vendors cannot accept enterprise business risk.

Question 11 (CISM4-011)

Correct answer: A - Reduce disruption to critical services within risk tolerance over two years.

The selected objective defines a meaningful business and risk outcome with a time horizon. Tool volume is not an outcome, log review is an operational activity, and wholesale procedure replacement lacks strategic justification.

Question 12 (CISM4-012)

Correct answer: D - The operating model and threats change dependencies, exposure, and capability needs.

The new operating model changes internal dependencies and stakeholders, while the threat trend changes external exposure; together they shape strategic needs. Considering only one dimension is incomplete, and waiting for a loss would make strategy reactive.

Question 13 (CISM4-013)

Correct answer: C - Define governance capabilities and prioritize initiatives closing ownership and criteria gaps.

The gap analysis should lead to target governance capabilities and prioritized initiatives addressing ownership and consistent criteria. A platform should follow defined needs, record volume does not prove decision quality, and retaining fragmented methods prevents the desired state.

Question 14 (CISM4-014)

Correct answer: D - Its fit with objectives, risks, obligations, operations, and existing practices.

Framework selection should be driven by organizational fit and the ability to support objectives, risk, obligations, and existing governance. Unique terminology and vendor claims do not establish suitability, while responsible tailoring is normally necessary rather than a defect.

Question 15 (CISM4-015)

Correct answer: A - Identity governance because it enables an approved enterprise objective and addresses associated access risk.

Identity governance has the strongest combination of business enablement and material risk treatment. Visibility and document volume are weak measures of strategic value, while spreading insufficient funds may prevent delivery of any meaningful outcome.

Question 16 (CISM4-016)

Correct answer: C - Leadership sponsorship has not produced the ownership decisions required for execution.

Effective sponsorship must resolve cross-functional ownership and provide authority for execution, not merely approve a strategy. More meetings or products do not settle accountability, and external developers cannot own the enterprise's information decisions.

Question 17 (CISM4-017)

Correct answer: B - Reassess risks and capabilities against the new business process and target architecture.

The changed process and architecture require a reassessment of risks, desired capabilities, and investments. Continuing the old roadmap creates misalignment, purchasing before defining needs is premature, and architects are partners rather than owners of the information security strategy.

Question 18 (CISM4-018)

Correct answer: C - The percentage of dormant accounts disabled within the approved time limit

Timely disabling of dormant accounts directly measures the risk outcome. Template counts, recipients, and procedure length measure administrative inputs or activity without demonstrating that exposed accounts are being removed.

Question 19 (CISM4-019)

Correct answer: A - Compare current capabilities with the integration strategy and target architecture before approving investments.

Current capabilities, integration goals, and target architecture should guide consolidation, transition controls, and investment. Renewing everything may create stranded cost, process length does not establish suitability, and delaying governance allows incompatible decisions to become embedded.

Question 20 (CISM4-020)

Correct answer: B - Use targeted training and temporary specialist support while retaining enterprise ownership and oversight.

A blended plan can meet the timeline, develop internal knowledge, and preserve enterprise accountability. Abandoning the capability ignores strategic need, consultants cannot own the enterprise's risk, and tools do not replace skilled judgment and governance.

Question 21 (CISM4-021)

Correct answer: A - Expected outcomes, risk reduction, costs, alternatives, assumptions, and dependencies

A business case enables informed comparison by explaining outcomes, risk reduction, costs, alternatives, assumptions, and dependencies. Product features, available budget, or supporter counts alone do not establish the investment's enterprise value.

Question 22 (CISM4-022)

Correct answer: D - Evaluate total value, assurance access, measurable outcomes, oversight, resilience, and exit needs before selection.

Strategic sourcing requires evaluation of outcomes, total cost and value, assurance, oversight, resilience, and exit capability. Lowest price alone can conceal lifecycle risk, providers cannot define enterprise risk appetite, and operations may be outsourced while accountability remains internal.

Question 23 (CISM4-023)

Correct answer: A - Connect initiative progress, risk and outcome trends, resources, and decisions to objectives.

Governance reporting should connect delivery, outcomes, exposure, resources, and required decisions to strategic objectives. Raw technical events overwhelm decision-makers, removing targets hides effectiveness, and reporting only favorable projects creates an incomplete view.

Question 24 (CISM4-024)

Correct answer: C - Escalate the breach, impacts, and treatment options to authorized decision-makers.

A sustained tolerance breach requires transparent escalation, impact analysis, and authorized treatment or acceptance. Automatically changing the threshold disguises exposure, suspending measurement removes oversight, and the security manager cannot personally accept all enterprise supplier risk.

Question 25 (CISM4-025)

Correct answer: B - The policy conflicts with the strategy and may reinforce incorrect ownership.

Policy should translate strategic direction into consistent authority and expectations; conflicting ownership language can undermine execution. Policies appropriately assign responsibilities, legacy policy should be updated when strategy changes, and alignment is required beyond technical standards.

Question 26 (CISM4-026)

Correct answer: B - Revise affected priorities, initiatives, measures, and resource assumptions based on the new evidence.

Strategy maintenance should incorporate performance evidence and material environmental changes even when top-level objectives remain stable. Automatic renewal ignores evidence, wholesale replacement is disproportionate, and excluding newly material risk would leave the strategy incomplete.

Question 27 (CISM4-027)

Correct answer: C - Reconcile business goals, obligations, architecture, risk appetite, and capability priorities.

Integrated governance is needed to reconcile expansion goals, legal constraints, information architecture, risk boundaries, and investment priorities. Funding everything may create duplication, unrelated strategies weaken enterprise direction, and architecture choices must incorporate applicable obligations.